

SECURITY QUESTIONNAIRE ANSWERS

IntelliBase AI · Annex B to the Subscription Agreement (for information) · As of 24 September 2026

Provided to :

Date :

1. ARCHITECTURE AND DATA LOCATION

Question	Answer
Service model?	Multi-tenant web-based SaaS. Nothing is installed on the Customer's servers.
Where is data stored?	PostgreSQL database on Neon, AWS Singapore region (ap-southeast-1). The application runs on Vercel.
Does data leave Indonesia?	Yes. The database, hosting and AI providers (Google Gemini, Groq) are outside Indonesia. This is disclosed in the Privacy Policy and the Data Processing Agreement.
Are original files stored?	No. Files are extracted to text; only the text, chunks, vectors and summary are stored.
Who are the sub-processors?	Google (Gemini API), Groq, Neon, Vercel, Resend, Midtrans, and Slack if the integration is enabled. Details are in Section 4 of the Data Processing Agreement.

2. TENANT ISOLATION, ACCESS AND AUTHENTICATION

Question	Answer
How is our data separated from other customers?	PostgreSQL row-level security (RLS). Every database transaction sets the company ID, and RLS policies reject rows belonging to other companies. If application code is wrong, the result is zero rows, not another customer's data. This isolation has been tested with a database role that has no bypass privilege.
How are passwords stored?	As hashes, never in plain text.
Is MFA/2FA available?	Yes, two-factor authentication (TOTP) is available to every user. Administrators cannot yet enforce it for all users.
Is SSO available?	Not yet.
Role model?	Administrator (manages documents, users, subscription) and employee (asks questions). Permissions are checked server-side on every endpoint.
How are leavers' accounts handled?	The administrator sends a request to hello@intellibaseai.com and our team deactivates the account within 1 business day. Self-service deactivation by administrators is in development.

Who at the vendor can access our data?	Only the technical operator, for support and maintenance, bound by confidentiality.
Protection against attacks?	Per-IP rate limiting, Content Security Policy, HSTS, automated security scanning (OWASP ZAP) in the CI pipeline, and regular internal security reviews and penetration tests.

3. ENCRYPTION AND USE OF DATA BY AI

Question	Answer
Encryption in transit?	Yes, HTTPS/TLS for all traffic, with HSTS.
Encryption at rest?	Yes, storage encryption by the database provider (Neon/AWS). Customer-supplied API keys (BYOK) are additionally encrypted with AES-256-GCM. Public API keys are stored as hashes.
Which AI models are used?	Answers are generated by Groq-hosted models, with Google Gemini as fallback. Document indexing uses a Google Gemini embedding model.
Is our data used to train AI models?	Groq states it does not use API data for training. For Gemini, see the option ticked in Section 4(1) of the Data Processing Agreement: a paid Gemini account from the Provider, or the Customer's own API keys (BYOK).
Can AI answers be wrong?	Yes. Every answer includes citations to the source document so it can be verified. If the information is not in the documents, the system says so instead of guessing.
Does the AI answer from general knowledge?	No. Answers are limited to relevant excerpts from the Customer's documents (retrieval-augmented generation).

4. MONITORING, INCIDENTS, BACKUP AND CONTINUITY

Question	Answer
How are errors and outages detected?	Server-side errors are logged and sent as automatic email alerts to the operator.
How long are logs kept?	Up to 90 days at the infrastructure providers.
Data breach procedure?	The Customer is notified no later than 48 hours after an incident becomes known, with details of the data affected and the response (Data Processing Agreement, Section 5).
Backups?	Automated backups and point-in-time restore by the database provider, Neon.
Is there a written disaster recovery plan (DRP)?	There is no tested written DRP yet. Recovery relies on Neon backups and redeploying the application from its repository.
What if the vendor stops operating?	The Customer is notified at least 30 days in advance and may request an export of chat history. Original documents remain with the Customer.

Availability target?	99% per month on a best-effort basis; no SLA with service credits yet.
----------------------	--

5. WHAT WE DO NOT HAVE YET

We disclose this section openly so the Customer can assess the risk from the start.

Question	Answer
ISO 27001 / SOC 2 certification?	Not yet.
Independent third-party penetration test?	Not yet. Penetration tests and security reviews have so far been carried out internally.
Servers in Indonesia?	Not available yet.
Audit log of administrator actions?	Not yet. Question and answer history per user is available.
SSO and mandatory 2FA for all users?	Not available yet.
Self-service data export/deletion for data subjects?	Not yet; handled manually via hello@intellibaseai.com within 30 days.

6. VENDOR LEGAL DETAILS

Business form :

Business ID (NIB) :

Tax ID (NPWP) :

VAT status : ☐ PKP (VAT-registered) ☐ Non-PKP

PSE registration (Komdigi) :